

Project Submission Details

Project Name:	SafeHire: Verified Credential & Skill-Match Recruitment Portal
Group Members:	1. Muhammad Umar Afzaal (Roll No: 23F-3106) • 2. Musa Rehan (Roll No: 23F-3093)
Live / Local URL:	https://safehire-secdev.vercel.app/ Local: http://localhost:3000/ (Vite)
Repository:	https://github.com/muhammadumarafzaal/safehire-secdev

Part 1 — Select Two User Roles

Role 1:	Student Job Seeker (<i>Muhammad Umar Afzaal — Roll No: 23F-3106</i>) Primary candidate stakeholder. Accesses verified degree badges, applies to vetted positions with prompt-injection defense, and controls contact disclosure through a mutual consent state machine.
Role 2:	University Placement Officer (<i>Dr. Tariq Mahmood — Officer ID: PO-FAST-092</i>) Institutional regulatory authority. Audits student academic transcripts, issues cryptographic SHA-256 HMAC credential signatures, and approves or revokes corporate recruiter postings.

Part 2 — Define What Each Role Can Do (3 Functions Each)

Role 1: Student Job Seeker	1. View Verified Academic Badges & Cryptographic Audit Hash: Inspects official CGPA and tamper-proof SHA-256 transcript digest (Audit ID: 0x8F22A). 2. Search, Filter & Apply with Prompt-Injection Defense: Explores career matches and submits cover notes through an active AST scanner intercepting adversarial overrides. 3. Enforce Selective PII Disclosure / Accept Offer: Operates the 4-step state machine (<i>Applied</i> → <i>Offered</i> → <i>Accepted</i> → <i>Revealed</i>) to release contact info.
Role 2: Placement Officer	1. Cryptographically Authenticate & Sign Transcripts (Role-Restricted): Inspects pending student queue, computes SHA-256 HMAC block digests, and commits verified credentials. 2. Audit & Vet Corporate Recruiter Partnerships: Inspects company NDAs and fair-stipend policies; approves or revokes corporate posting access. 3. Monitor System-Wide Security Audit Telemetry: Reviews live logs of role authorizations, PII access nonces, and blocked prompt-injection security events.

Part 3 — Create Demo Users

Demo User	Assigned Role	Email & Password	Authorization Scope & Identifier
Muhammad Umar Afzaal	Student Job Seeker	m.umar@nu.edu.pk SafeHire#2026!Sec	Roll No: 23F-3106 • CGPA: 3.78 Audit Digest: 0x8F22A (Verified)
Dr. Tariq Mahmood	Placement Officer	placement.officer@nu.edu.pk Officer#2026!Safe	Officer ID: PO-FAST-092 • Level-3 Registrar Key: FAST-ED25519-2026

Part 4 — Make the Login Page Functional

The login page (src/pages/LoginPage.jsx) provides full functional role authentication:

- **Interactive Role Switcher & Quick-Fill Demo Buttons:** Evaluators click 1-click shortcuts for either *Muhammad Umar Afzaal* or *Dr. Tariq Mahmood* to instantly populate credentials.
- **Input Validation & Password Strength Evaluator:** Validates institutional email domains and computes real-time password entropy.
- **Role Recognition & Dynamic Interface Routing:** Verifies role membership and redirects students to the **Student Job Seeker Portal** and placement officers to the **Placement Officer Console**.

Part 5 — Create Role-Specific Dashboards

Student Job Seeker Dashboard (StudentDashboard.jsx)	Placement Officer Console (OfficerDashboard.jsx)
• Profile: Welcomes Muhammad Umar Afzaal (23F-3106) with verified FAST badge. • Stats: Badges Verified (3), Active Applications (4), Interview Offers (1). • Selective Disclosure Card: 4-stage Stepper with PII reveal trigger. • PII Protection Display: Data minimization toggle (Phone: +92 3•• ••• ••21). • Job Table: Real-time filter tabs and prompt injection defense scanner. • Role Boundary Test: Button to simulate unauthorized officer action. • Logout: Dedicated sign out clearing session state.	• Profile: Welcomes Dr. Tariq Mahmood (PO-FAST-092) with institutional key badge. • Stats: Pending Transcripts (3), Vetted Employers (14), Signed Badges (8). • Role-Restricted Functional Console: Review candidate queue (Musa Rehan, Ayesha Khan) & click Sign Transcript to issue SHA-256 HMAC digest. • Recruiter Vetting Registry: Approve/Revoke corporate employer access. • Officer Least Privilege Scope: Segregates academic records from private chats. • Live Security Telemetry: Audit feed of hashes, PII locks, and violations. • Logout: Working session termination button.

Part 6 — Test the Difference Between the Roles

Test	Expected Result & Actual Verification
Role 1 logs in	System authenticates student; loads Student Job Seeker Portal with applicant profile and job explorer.
Role 2 logs in	System authenticates officer; loads Placement Officer Console with institutional administration controls.
Role 1 views its dashboard	Displays applicant features: personal verified GPA (3.78), selective contact stepper, and PII masking.
Role 2 views its dashboard	Displays administrative features: pending transcript queue, corporate approvals, and cryptographic signing tool.

Part 7 — Protect a Function From the Wrong Role

Function Selected: `issueCryptographicTranscriptSignature(studentId)`
Authorized Role: Placement Officer (Role 2)
Defensive Logic: `IF user.role === 'Placement Officer' THEN performFunction() ELSE displayAccessDeniedModal('403 Forbidden')`
Observed Behavior: An interactive test button is provided on the Student Dashboard. When the student attempts this action, execution immediately halts, an `AUTHZ_POLICY_REJECTION` audit event is logged, and an explicit **403 Forbidden Access Denied Modal** is rendered explaining that the Principle of Least Privilege and Separation of Duties prevent students from self-attesting academic records.

Part 8 — Add One Security-Aware Data Display

Selected Information: Student Personal Identifiable Information (PII) — Personal Phone Number (+92 300 1234567) and National Identity / CNIC (35201-1234567-1).
Who should be allowed to see it? Only the authenticated student candidate (data owner) and recruiters who have received explicit mutual consent via an accepted interview offer.
Implementation: Displayed in masked form (+92 3•• ••• ••21 and 35201-•••••••-7) under the Principle of Data Minimization (OWASP / GDPR Art. 5(1)(c)). The prototype features an interactive view toggle demonstrating recruiter masking vs owner unmasking.

Part 9 — Add Logout

Dedicated Logout buttons are integrated into the top navigation bar and dashboard headers. When clicked:

1. Active session state is completely purged (`user = null`).
2. The application redirects to `/login` with an informative security toast.
3. **Protected Route Guard:** If unauthenticated users attempt to navigate to dashboard, `App.jsx` intercepts and redirects them to the login screen with a warning notice.

Part 10 — Test Your Prototype Results

Test Case	Action Performed	Observed Result	Status
Test 1 — Correct Role	Log in using valid Student credentials (m.umar@nu.edu.pk).	System validates role; loads Student Job Seeker Portal with Umar's credentials and verified badge 0x8F22A.	PASS
Test 2 — Different Role	Log out and log in using Placement Officer credentials (placement.officer@nu.edu.pk).	System validates role; loads Placement Officer Console with verification queue and signing tools.	PASS
Test 3 — Restricted Function	Attempt to invoke issueCryptographicTranscriptSignature as Student.	Execution halted; 403 Forbidden Access Denied Modal rendered; security violation logged to ledger.	PASS
Test 4 — Logout	Click Logout from navbar or dashboard header.	User state purged; returned to login page; protected dashboard inaccessible without re-authentication.	PASS

Part 11 — Security Development Note

Security Concept Applied:	Role-Based Access Control (RBAC), Separation of Duties, Principle of Least Privilege (PoLP), Fail-Safe Defaults, and Data Minimization.
Where did you apply it?	Authentication dispatcher (LoginPage.jsx), client-side route guard (App.jsx), functional execution handlers (handleSignTranscript & handleAttemptRestrictedAction), and candidate PII masking cards.
What did you change?	Engineered dual role-segregated dashboards (StudentDashboard.jsx and OfficerDashboard.jsx); added cryptographic transcript signing for officers; built 403 Access Denied guardrail modal; enforced session purging upon logout; enhanced responsive UI layouts.
What happens upon unauthorized attempt?	System evaluates user.role === 'Placement Officer'. When evaluated false, execution immediately terminates before any state change occurs. An AUTHZ_POLICY_REJECTION event is dispatched to the audit trail, and an explicit 403 Forbidden Access Denied dialog informs the actor that Placement Officer privileges are required.

Activity 2 Submission Checklist & Summary

Requirement Checklist	Verification Status in SafeHire Implementation
• Same project selected in Activity 1	SafeHire recruitment portal continued seamlessly without separate application.
• Two functional user roles	Role 1: Student Job Seeker • Role 2: University Placement Officer.
• Functional login for demo users	Credential validation and 1-click Quick-Fill shortcuts for both demo users.
• Role-specific dashboard / interface	Separate Student Portal and Placement Officer Console with distinct actions.
• At least one role-restricted function	issueCryptographicTranscriptSignature() restricted to Placement Officer.
• Protected or limited information	Personal phone and CNIC masked under Data Minimization (OWASP / GDPR).
• Working logout	Purges user session state and enforces protected route guard.
• Testing of both roles	Tests 1 to 4 executed with 100% PASS rate across both roles.